

## מיהו הארגון הנסקר.

### שלב א': רקע

- במה עוסק הארגון? איפה נמצא המידע, מה השירות שמציע הארגון, צריך לתאר שהשירות?
- איפה ארגון ממוקם פיזית, כמה שנים הוא קיים?
- מה תרבות הציות בארגון (קיומם של נוהל)? כך למשל ארגון פיננסי, הצפי שיהיה בא נושא מוסדר של נהלים. כמו כן במקום שאין כלום, עדיף להתחיל מנושאים חשובים.
- האם הארגון מוסמך ISO/SOC/PCI? מדובר על הסמכות של אבטחת מידע.
- איזה כללים מיוחדים שחלים על הארגון? ארגון כגון בנק, בית חולים, יש להם עוד חוקים שחלים עליהם, ויש עליהם רגולטור, צריך לציין את הנושא בעבודה.
- מי הלקוחות והיכן החברה נמצאת (ישראל או ארה"ב)?

## ■ מי הלקוחות (B2G/B2B2C/B2C/B2B), ישראל או חו"ל?

### שלב ב': מאגרי המידע

#### איזה מאגרי מידע קיימים?

- מאגר לקוחות.
- עובדים או מועמדים.
- ספקים- ספקים שהם עוסק מורשה יכול להכיל מידע אישי, כי המזהה הוא ת.ז של בעל העסק.
- מצלמות אבטחה.
- הרשימה היא לא רשימה סגורה. למשל רשות מקומית לכל אגף יש התנהלות שונה. יש לחשוב על מקום של הפרדת המאגרים.

## מאגרי מידע (המשך)

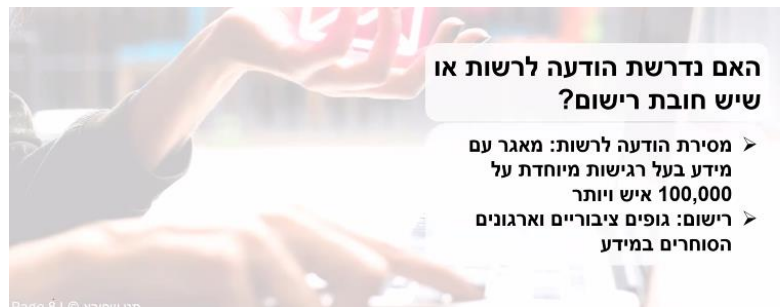
### יש 3 רמות אבטחת מידע

| רמת אבטחה גבוהה                                                                                                                                                    | רמת אבטחה בינונית                                                                                                                                                                                                                                                                                                                                                                    | רמת אבטחה בסיסית                                                                                                                                   |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <ol style="list-style-type: none"> <li>עומד בקריטריון רמת אבטחה בינונית</li> <li>מכיל מידע על למעלה מ-100,000 אנשים או מספר בעלי הרשאות גישה גדול מ-100</li> </ol> | <ol style="list-style-type: none"> <li>מטרה עיקרית: איסוף מידע לצורך מסירתו לאחר כעיסוק עיקרי כולל דיוור ישיר גוף ציבורי</li> <li>כולל: צנעת חייו האישיים של אדם, מידע רפואי, מידע גנטי, מידע על דעות פוליטיות, מידע על עבר פלילי, נתוני תקשורת, מידע ביומטרי, מידע על נכסיו של אדם וכו', הרגלי צריכה.</li> <li>*חריג: נשמר על מועסקים/ספקים או אין יותר מ-10 הרשאות גישה</li> </ol> | <ol style="list-style-type: none"> <li>על דרך השלילה; לא בינונית או גבוהה</li> <li>מנוהל ע"י יחיד או תאגיד בבעלות יחיד-עד 3 הרשאות גישה</li> </ol> |

1. עורכי דין/ רו"ח - רמת אבטחה בינונית.

לכל מאגר צריך לקבוע סיווג מאגר

2. האם נדרש הודעה לרשות או שיש חובת רישום?



**האם נדרשת הודעה לרשות או שיש חובת רישום?**

- מסירת הודעה לרשות: מאגר עם מידע בעל רגישות מיוחדת על 100,000 איש ויותר
- רישום: גופים ציבוריים וארגונים הסוחרים במידע

האם יש הסכמה ויידוע של נושאי מידע?

שלב ג': אחריות ארגונית

האם יש לארגון? ממונה על הגנת הפרטיות.

1. האם יש ממונה אבטחה (CISO).

2. מסמכי הגדרות מאגר. אם המידע נמצא אצל מחזיק מאגר, אין צורך ברישום המאגר ולא חייב במסמכי הגדרות המאגר.

3. מיפוי מערכות ורשימת מצאי. היכן המידע נמצא. ה-DPO אמור לתכלל בין האגפים השונים של המידע המצוי בארגון. מקצוע ה-DPO הוא יחסית חדש ונמצא בהתהוות.

ברוב הארגונים אין דרישה שיהיה DPO במשרה מלאה.

שלב ד': דרישות אבטחת מידע

**תקנות הגנת הפרטיות (אבטחת מידע), תשע"ז-2017**

רשימה חלקית של דרישות שהארגון נדרש לעמוד לפי התקנות.



**שלב ד': דרישות אבטחת מידע**

**תקנות הגנת הפרטיות (אבטחת מידע), תשע"ז-2017**

- ✓ נוהל אבטחה
- ✓ אבטחה פיזית וסביבתית
- ✓ סקר סיכונים ומבחני חדירות
- ✓ ניהול הרשאות גישה
- ✓ זיהוי ואימות
- ✓ בקרה ותיעוד גישה (לוגים)
- ✓ גיבויים
- ✓ אבטחת תקשורת
- ✓ תיעוד אירועי אבטחה

ה-DPO אמור להנחות את הארגון שהתקנות מיושמות.



- א. צריך לבדוק האם יש תהליך של אישור ספקים בארגון. האם יש מדיניות כתובה של אישור התקשרויות/ ספרים.
- ב. מומלץ שיהיו הסכמי סודיות עם ספקים, במידה יש לו גישה למידע אישי.

### איך תראה העבודה בפועל

מציגים סקר פרטיות לדוגמה ( המצגת תעלה לדרייב).

1. **תמצית מנהלים** -סיכום של העובדה שעשינו ומה המסקנות, ומה מבקשים. אנחנו לצורך התרגול סוקר חייוני של החברה. צריך להציג תמצית מנהלים במצגת ביום 4.2.2026.

## תמצית מנהלים

משפט קצר עליכם ועל החברה הנסקרת.  
זכרו: המנהלים מכירים את החברה שלהם,  
אבל לא את החוק או את ממצאי הסקר



ממצאים עיקריים בסקר ולקחים מרכזיים  
לביצוע עבור הארגון



2. שלב ראשון: רקע אודות הארגון:

סקר פרטיות - דוגמה

### רקע: אודות הארגון

כל מידע רלוונטי: מתי הוקם, מספר עובדים,  
תחום פעילות, סוגי השירותים שהוא מציע, סוגי  
הלקוחות, חברות אם/ בנות/ קשורות

# מסגרת נורמטיבית

אילו חוקים, תקנות, או גופים מנחים  
רלוונטיים לחברה או לפעילות שלה?

1. מקורות כללים. כגון: חוק הגנת הפרטיות
2. מקורות ספציפיים לפי שירותים מוצעים. כגון: אנרגיה, פיננסים, הימורים, שירותים רפואיים, שירותי פרסום, סליקה
3. מקורות ספציפיים על גופים ספציפיים. כגון: בנקים, בתי חולים, גופים בטחוניים, משרדי עורכי דין

## 3. סיווג מאגר מידע

סיווג מאגרי מידע

| מאגר 1 [שם מאגר]                                 | [שם מאגר] | [שם מאגר] | [שם מאגר] |
|--------------------------------------------------|-----------|-----------|-----------|
| <input type="checkbox"/> איזה סוגי מידע יש במאגר |           |           |           |
| <input type="checkbox"/> סיווג רמת אבטחה         |           |           |           |
| (בסיסית, בינונית, גבוהה),                        |           |           |           |
| כולל נימוק קצר                                   |           |           |           |
| <input type="checkbox"/> האם הארגון בעל שליטה    |           |           |           |
| או מחזיק                                         |           |           |           |
| <input type="checkbox"/> אם בעלים: (i) האם       |           |           |           |
| המאגר מחייב הודעה, (ii)                          |           |           |           |
| האם קיים מסמך הגדרות                             |           |           |           |
| מאגר                                             |           |           |           |
| <input type="checkbox"/> מי המחזיקים העיקריים    |           |           |           |

בנוסף, לציין אם יש מחזיקים מרכזיים של המאגר (פריורטי וכו')

## יש 2 סוגי מחזיקים

4. יש מחזיק שהוא תוכנה- כמו מייקרוסופט.

5. יש מחזיק שנותן לנו תמיכה ויש לו גישה למידע שלנו הוא מחזיק.

האם החברה עומדת בהוראות בתקנות הגנת הפרטיות?

האם החברה עומדת בתקנות הגנת הפרטיות?

[#1 דוגמה: נוהל אבטחה]



מה החובה  
(בקצרה)

כתיבה ואישור של נוהל אבטחת  
מידע

מה המצב  
הנוכחי

לא קיים

הפער – מה  
נדרש?

על החברה להכין נוהל ולהביאו  
לאישור ההנהלה

חשוב!

- (א) יש לבחון את הדרישות העיקריות שבתקנות הגנת הפרטיות (אבטחת מידע)  
(ב) בחינת מינוי DPO (אם קיימת חובה כזו)  
(ג) את אופן היידוע של נושאי המידע

אין חובה לעבור על כל תקנה. (סעיף ב'-וג')

סקר פרטיות - דוגמה

CCPA, GDPR: האם חל ומדוע?

צריך לציין האם חל על האגון, האם חל/ לא חל ולתת נימוק.

פרק סיום

סקר פרטיות - דוגמה

## סיכום

### מסקנות עיקריות:

מהן ההמלצות העיקריות ליישום עבור החברה.  
**הערה:** ההמלצות יהיו לפי סדר הגיוני כלשהו (עלות, קלות ביצוע, תועלת) בצורה פשוטה וקריאה - עדיף במילים ולא בטבלה.





## מתי חובה למנות ממונה הגנת פרטיות (DPO)?

“

- ✓ גוף ציבורי / מאגר של גוף ציבורי
- ✓ גוף הסוחר במידע (10,000 איש)
- ✓ ניטור שוטף ושיטתי של מידע אישי כדרך עיסוק
- ✓ עיבוד מידע בעל רגישות מיוחדת בהיקף נרחב

”

גם מחזיק של מאגר של גוף ציבורי חייב למנות DPO.

כלל אצבע בהיקף נרחב – 1000 איש.

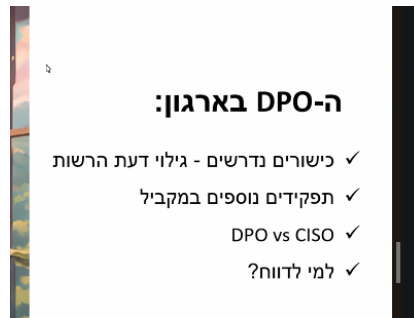
## תפקידי ה-DPO

הבטחת קיום ההוראות וקידום השמירה על פרטיות ואבטחת מידע, כולל:

- סמכות מקצועית ומוקד ידע, ייעוץ להנהלה, הכנת תכנית הדרכה ופיקוח על הביצוע
- תכנית בקרה ווידוא ביצוע, דיווח להנהלה על ממצאים והצעות לתיקון
- וידוא קיום נוהל אבטחה ומסמך הגדרות, לאישור הנהלה
- טיפול בפניות ואיש קשר לרשות

ה-DPO אינו אחראי על יישום הוראות הדין.

אין אחריות אישית על DPO.



### על מנת להיות DPO צריך 2 תנאים:

צריך לימודי DPO במוסד מוכר.

צריך ניסיון בתחום.

יש הנחיות שונות של רשות מי לא יכול להיות DPO, כמו CISO.

חובת דיווח – למנכ"ל או מי שהמנכ"ל הסמיך לכך.

ה-DPO הוא סוכן פרטיות בארגון, הוא צריך להיות עם הכרות עם טכנולוגית המידע, רקע משפטי, מוביל בארגון, לדעת להציג להנהלה, גורם מאפשר/ מעכב, צריך הבנה עסקית, שתהיה גישה נכונה.

### מי יכול להיות DPO, מה הכישורים הנדרשים?

